任务 1：数据库与查询条件基础说明

1. 页面中的输入为什么会与数据库查询有关

因为页面显示的所有信息实际上全都存在数据库里，网页本身是空的，用户在页面上输入的内容就是在告诉系统“我要查什么”，方便从数据库查询并显示。所以说页面功能与数据库有关，因为没有数据库的话，网站记不住那么多内容，也就看不到任何信息。

2.一个最小业务链路是什么

例如：输入条件 → 数据库查询 → 返回结果

用户输入 → 后端程序接收 → 拼接 SQL → 数据库执行查询 → 返回结果给用户

3.用户输入是如何进入查询条件的

后台收到输入的东西后会把它当成一个“值”，放到某个查询语句，这样就可进入查询条件。

4. 为什么这为 SQL 注入创造了可能性

可能有的时候输入的代码并非某个字符，而是一串字符，这样数据库就会把能查到的全显示出来，即输入没有被当成纯数据，而是被允许进入了查询结构的构造过程。

任务 2：DVWA SQL Injection Low 现象记录

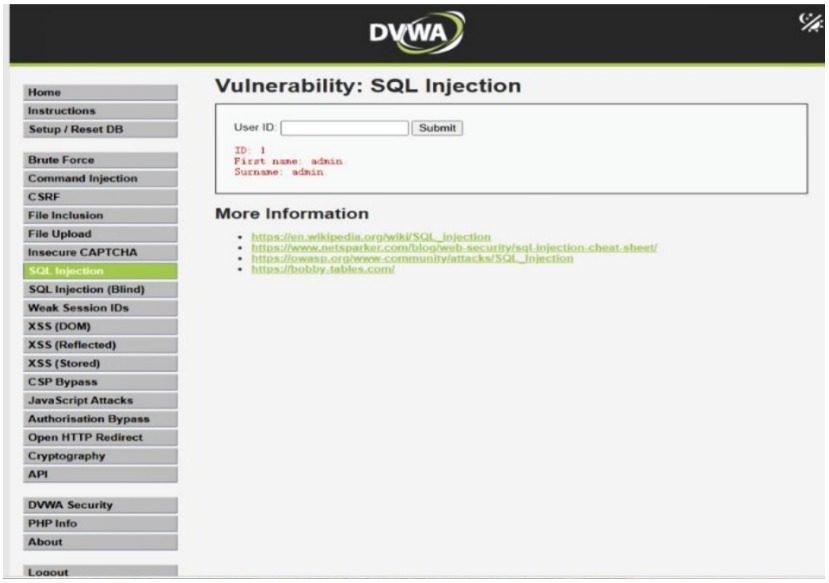
1. 实验页面或实验目标

实验页面：DVWA → SQL Injection → Low 级别页面

实验目标：观察并对比普通输入和 SQL 注入异常输入时页面的返回差异，验证是否存在 SQL 注入漏洞。

2. 普通输入与异常输入的对比

输入 1，返回对应单条用户记录，格式固定、字段正常，如下图：



输入 1’，直接报数据库错误，如下图：

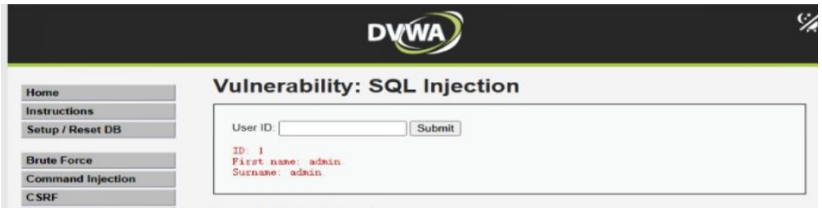
差异对比：

普通输入：返回正常用户数据

异常输入：返回 SQL 语法错误，没有用户数据

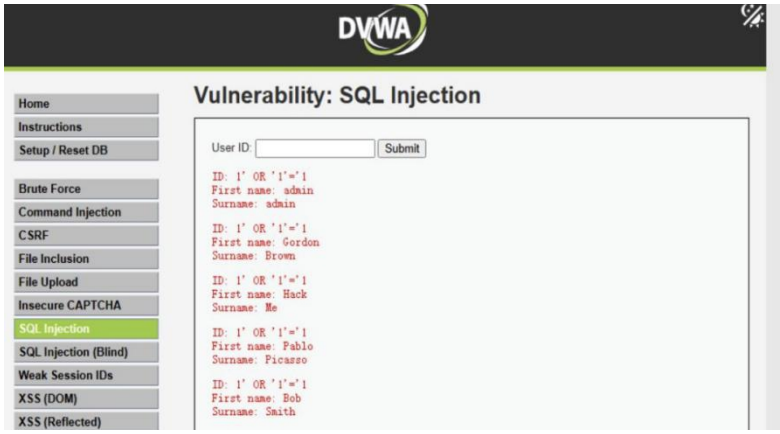
3. 返回结果的差异

普通输入 1：后端执行 SELECT first_name, last_name FROM users WHERE id = '1'，页面返回 ID=1 的 admin 用户数据，结果正常且固定。



异常输入 1'：后端拼接为 SELECT ... WHERE id='1''，页面返回 SQL 语法错误，无数据返回。该差异说明输入的单引号被直接解析为 SQL 语句的一部分，而非单纯的字符串值。

异常输入 1' OR 1=1 -- ：后端拼接为 SELECT ... WHERE id='1' OR 1=1 -- '，页面返回数据库中所有用户的多条数据。该差异说明输入的逻辑运算被执行，改变了原查询的条件。



4. 为什么这种差异不像“正常查询变化”

正常查询中用户输入仅作为查询值，不会影响 SQL 语法结构和逻辑，如输入不存在的 ID 只会提示无数据，不会报错或改变返回条数。而本次实验中，异常输

入可以触发语法错误、改变查询逻辑、获取全表数据，这些都是 SQL 注入漏洞的典型现象，因此不是正常的查询结果变化。

任务 3：机制分析与差异比较

1. 输入如何进入查询结构

①输入：在输入框里输入内容②拼接：后台收到输的内容后，直接把它放到查询语句的某个位置上。③解析：数据库收到这条完整的查询语句，开始分析这句话是什么意思。它分不清哪些是原来的结构、哪些是后加的，因为已经焊死了。④执行：数据库按照解析出来的意思去执行查询，把结果找出来。⑤回显或行为差异：页面把查询结果显示出来，或者根据查询结果表现出不同的行为（比如显示“存在”或“不存在”）。

2. 为什么根因是“结构被污染”而不是“字符本身危险”

比如”；”这个字符本身无意义，只是 SQL 中的符号，但被输入之后，通过拼接进入查询结构，从而改变了查询原本的逻辑。

3. Low 与 Medium 的差异在哪里

Low 没有门槛，用户输入什么，后台就直接拼什么，查询语句完全由用户控制。所以随便一个 1' or '1'='1 就能把全部数据显示出来。
Medium 则是后端对用户输入的内容做了一些处理。它会把输入内容里的特殊字符进行转义。当用户输 1' or '1'='1 的时候，单引号会被处理，没法提前闭合原来的条件，注入就失效了。

4. 普通 SQL 注入与 Blind SQL Injection 的差异在哪里

普通 SQL 注入：用户注入成功之后，数据库查到的结果会直接显示在页面上。比如我把所有用户数据炸出来，页面就会把这些名字、账号全部列出来给我看。用户能直观地看到注入的结果。
Blind SQL Injection：页面不会显示数据库查到的具体内容。页面只会告诉我“查询成功”或者“查询失败”，或者页面没有任何变化，甚至可能卡几秒才加载完。我看不到数据，只能通过页面的行为差异来判断我的注入有没有生效。

5. 为什么盲注和普通注入根因相同，但证据形式不同

普通注入：网站不隐藏信息，用户输入特殊符号，页面会直接报错、泄露数据，一眼就能看出注入成功，有直接看得见的证据。

盲注：网站屏蔽了报错、不泄露数据，页面永远只显示正常或异常，没有任何明文提示。只能靠页面变不变、加载快慢这种细微差别，间接推测出注入存在，靠的是间接推断的证据。

强制判断题

1. SQL 注入的根因更接近

A. 输入里有几个危险字符

B. 输入进入了不该进入的查询结构

我选 B 理由：SQL 注入的本质是用户输入被当作 SQL 指令的一部分解析，污染了原本的查询结构， 而非输入中的字符本身有危险性。即使没有特殊字符，只要输入能修改查询结构，依然会产生注入漏洞。

2.Blind SQL Injection 和普通 SQL 注入的最大差异更接近

A. 根因不同

B. 证据形式不同

我选 B 理由：两者的根因都是查询结构被污染，只是普通注入有直接数据回显，可直接获取数据；盲注无直接回显，只能通过页面行为差异推断数据，核心差异是证据形式而非根因。

任务 4：SQL 注入防护清单与解释

1.参数化查询（根因层）

彻底杜绝用户输入直接拼接 SQL 语句，把输入只当作参数值处理，无法篡改 SQL 语法结构，从源头堵死注入逻辑。不能替代输入校验、数据库最小权限、错误处理；即便用了参数化查询，恶意非法业务输入仍需校验，也不能放任数据库账号高权限

2.输入校验（暴露面层，缩小可被利用的输入入口攻击面）

对用户传入的参数做格式、长度、字符范围校验，只允许合法合规内容，拦截特殊符号、恶意语句等可疑输入。不能替代参数化查询；仅靠过滤校验容易被绕过，无法从语法层面杜绝 SQL 拼接漏洞。

3.错误处理（暴露面层，隐藏漏洞特征与后台结构信息）

关闭数据库原生 SQL 报错、堆栈信息对外展示，前端只返回通用提示，不泄露库名、表名、字段结构等敏感信息，攻击者无法通过报错判断注入点。但完全不修复注入漏洞本身，只是藏住证据，只能防探测，防不了已成型的盲注攻击。

4.最小权限（后果范围层）

给业务数据库账号只分配必要增删改查权限，禁止使用 root、sa 等高权限账号，限制跨库查询、删库、导出数据等高风险操作。但不能预防注入漏洞产生，只是出事以后减小损失，无法阻止攻击者构造恶意 SQL。

6. Web 应用防火墙 WAF（暴露面层）

基于特征库、行为规则拦截 SQL 注入关键字、特殊符号请求，在入口处拦截常见注入 payload。不能替代代码层安全修复，规则可被绕过，只能做防护补充，不能从根上解决漏洞。

收口项 1 SQL 注入因果链/防护关系图

核心因果链：输入→直接 SQL 拼接→查询结构被污染→解析执行→回显/行为差异→注入成功

防护对应关系：参数化查询阻断“拼接”环节（根因控制），输入校验减少暴露面，错误处 理隐藏证据，最小权限缩减后果范围。

收口项 2 学生自评表

1. 我本章最清楚的一点是什么？

彻底搞懂了普通 SQL 注入和盲注根因相同，只是页面反馈和证据形式不同；同时清晰记住了 SQL 注入四大防护措施：参数化查询、输入校验、错误处理、最小权限，以及各自对应的防护层级。

2.我最容易混淆的一点是什么？

容易混淆每种防护措施对应的层级，也容易搞混普通注入和盲注的判定逻辑。

3.我本次作业中哪一段最需要教师复核？

关于盲注与普通注入根因相同但证据形式不同的文字解释部分，以及各项防护措施分别对应分层判定，需要老师复核逻辑是否准确、定义是否贴合知识点要求。

4.如果重做一次，我会优先改哪一部分？

会补充更多 Medium 级别的实验现象记录，通过具体输入与返回差异，更直观地说明过滤 措施的局限性；同时完善因果链图示的细节，让防护措施与链路的对应关系更清晰。

收口项 3：AI 输出审核与人工复核记录

1. 本作业哪些内容使用过 AI 辅助？

盲注与普通注入异同的原理总结、SQL 注入防护清单逐条编写、分层归类。

2. 哪些判断是你自己复核后保留的？
确认参数化查询属于根因层
确认输入校验、错误处理属于暴露面层
确认数据库最小权限属于后果范围层
认可盲注和普通注入漏洞成因一致、仅页面反馈不同的核心结论

3.哪些内容你发现 AI 输出不准确并进行了修正？

修正了 AI 将“输入过滤” 描述为根因控制的错误，明确输入过滤属于暴露面控制，无法替 代参数化查询解决结构污染问题；补充了 DVWA 实验中的具体输入与返回细节，避免泛泛 而谈；修正了 AI 对盲注与普通注入根因的混淆表述，明确两者根因相同、证据形式不同。

3. 你最终如何确认结论和证据是一一对应的？

先明确 SQL 注入根本成因，再对应每种防护手段的作用原理；同时把每条措施的作用、层级、局限性互相校验，结论都对应了 DVWA 实验中的具体现象，并核对了 SQL 语句模板与现象的逻辑关系，确保结论均有实验证据支撑。

提交前自查清单

[√]我是否只在授权环境中完成实验

[√]我的截图是否已脱敏

[√]我是否说明了“正常查询变化”和“查询逻辑被改变”的区别

[√]我是否把根因写成“结构被污染”，而不是只写“特殊字符”

[√]我是否区分了普通 SQL 注入与盲注的证据差异

[√]我是否把参数化查询、错误处理、最小权限放回不同控制层

[√]我是否完成了关系图/关系表

[√]我是否填写了 AI 输出审核与人工复核记++